

SecureChain Project: 3-Person Work Plan

Wednesday to Monday (5-Day Sprint)

This document outlines the work distribution for three team members from Wednesday through Monday to prepare for the professor meeting. All team members can work simultaneously without blocking each other.

Already Completed: SETUP-001 (GitHub repo), SETUP-002 (AWS account), DOCS-001 (README), SWOT-001 (Cosign SWOT), APP-001 (Node.js app)

■ Person 1: Docker & Security Tools Setup

Focus: Security tooling and Docker operations | **Workload:** 9 tickets

Day 2 (Thursday)

- SETUP-004: Install Docker on local machine
- SETUP-009: Install Cosign CLI
- SETUP-010: Install Syft CLI
- SETUP-011: Install Gype CLI

Day 3 (Friday)

- SECURITY-001: Generate SBOM with Syft (run on the Node.js app)
- SECURITY-003: Scan with Gype (document output)
- SECURITY-006: Sign image with Cosign (generate keys, sign the image)

Day 4 (Saturday)

- APP-004: Test Docker build locally (ensure clean builds)
- DOCS-006: Create demo script for presentation (write Monday walkthrough)

Deliverables by Monday:

- ✓ Working Docker environment
- ✓ SBOM JSON file
- ✓ Gype vulnerability scan output
- ✓ Signed image with Cosign
- ✓ Demo script

■ Person 2: Testing & Vulnerability Creation

Focus: Creating test cases and documenting results | **Workload:** 6 tickets

Day 2 (Thursday)

- APP-002: Write package.json with dependencies (if not fully done)
- APP-003: Create Dockerfile for Node.js app (coordinate with Person 1)

Day 3 (Friday)

- TEST-001: Create 'vulnerable' version of Node.js app (use old Node base image like node:12)
- TEST-002: Test that Grype blocks the vulnerable image (screenshot the failures)

Day 4 (Saturday)

- DOCS-005: Document Security Gate Simulator test results (include screenshots)
- FINAL-002: Test entire pipeline end-to-end manually

Deliverables by Monday:

- ✓ Clean Node.js app (working version)
- ✓ Vulnerable Node.js app (for testing)
- ✓ Test results documentation
- ✓ End-to-end validation report

■ Person 3: Architecture & Documentation

Focus: Visual documentation and analysis | **Workload:** 7 tickets

Day 2 (Thursday)

- SETUP-002: Complete AWS Free Tier setup (configure billing alerts if needed)
- Research tools for architecture diagram (draw.io, Lucidchart, etc.)

Day 3 (Friday)

- DOCS-002: Create architecture diagram (GitHub → Docker → Syft → Grype → Cosign → ECR → K8s)
- SWOT-002: Research and create SWOT chart for Syft
- SWOT-003: Research and create SWOT chart for Grype

Day 4 (Saturday)

- SWOT-004: Format all SWOT charts consistently (clean up all 3 charts)
- DOCS-003: Document Jenkins pipeline stages (describe what each stage will do)
- Support FINAL-002 if needed (backup assistance)

Deliverables by Monday:

- ✓ Architecture diagram (presentation-ready)
- ✓ 3 SWOT charts (Cosign, Syft, Grype - all formatted consistently)
- ✓ Pipeline stage documentation

Summary by Person

Person	Ticket Count	Primary Focus
Person 1	9 tickets	Docker + Security Tools (Cosign, Syft, Grype)
Person 2	6 tickets	Vulnerable Testing + End-to-End Validation
Person 3	7 tickets	Architecture Diagrams + SWOT Analysis

Coordination & Communication

Thursday Night Check-in:

- Person 1: Docker installed, tools working
- Person 2: Dockerfile created (coordinate with Person 1)
- Person 3: AWS ready, architecture diagram draft

Friday Night Check-in:

- Person 1: SBOM file, Grype output, signed image
- Person 2: Vulnerable image ready

- Person 3: Architecture diagram + 2 SWOT charts complete

Saturday Night:

- Everyone: Review demo script together
- Ensure all pieces fit together
- Practice Monday presentation

Daily Communication Template

Daily Standup (Slack/Discord):

What I did today: [ticket numbers completed]

What I'm doing tomorrow: [ticket numbers planned]

Blockers: [any issues]

What You'll Have by Monday

- Working GitHub repo with code
- Dockerized Node.js app that builds successfully
- SBOM file generated from your image
- Vulnerability scan results (with screenshots)
- Signed container image with Cosign
- Vulnerable test image that shows failures
- Architecture diagram
- README documenting everything
- 3 completed SWOT charts

Note: All tools listed (Docker, Cosign, Syft, Gype) are free and open-source. This plan ensures no one is blocked waiting for others, workload is balanced (6-9 tickets per person), and everyone has clear domain expertise.